Threat Modeling d'un agent IA

Mini-projet « AI in Inclusive Education » — Jour 26

Kamal El Afoui

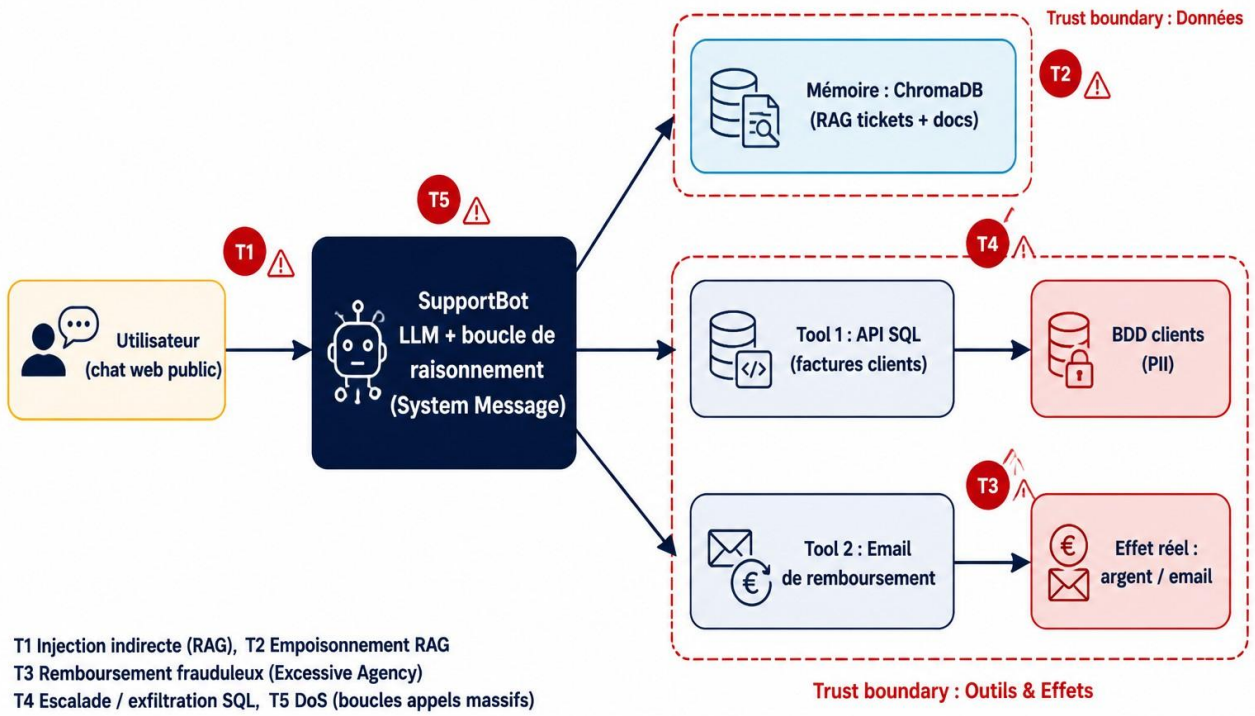
1. Contexte et objectif

Un agent IA n'est pas un simple modèle de langage : LLM + accès aux outils + autonomie = nouvelle surface d'attaque. L'objectif est de modéliser les menaces d'un agent de service client (SupportBot), de les prioriser avec la matrice **Risque = Probabilité × Impact**, puis de produire une Agent Card – Security exploitable par une équipe de développement.

- Référentiels **: OWASP LLM Top 10** (vision développeur / sécurité applicative) et **MITRE ATLAS** (vision attaquant / Red Team).
- Principe : « penser comme un attaquant » — le prompt est le vecteur d'attaque direct.
- Anatomie analysée : entrées et raisonnement (interne) ; outils, données et effets (externe), délimités par des Trust Boundaries.

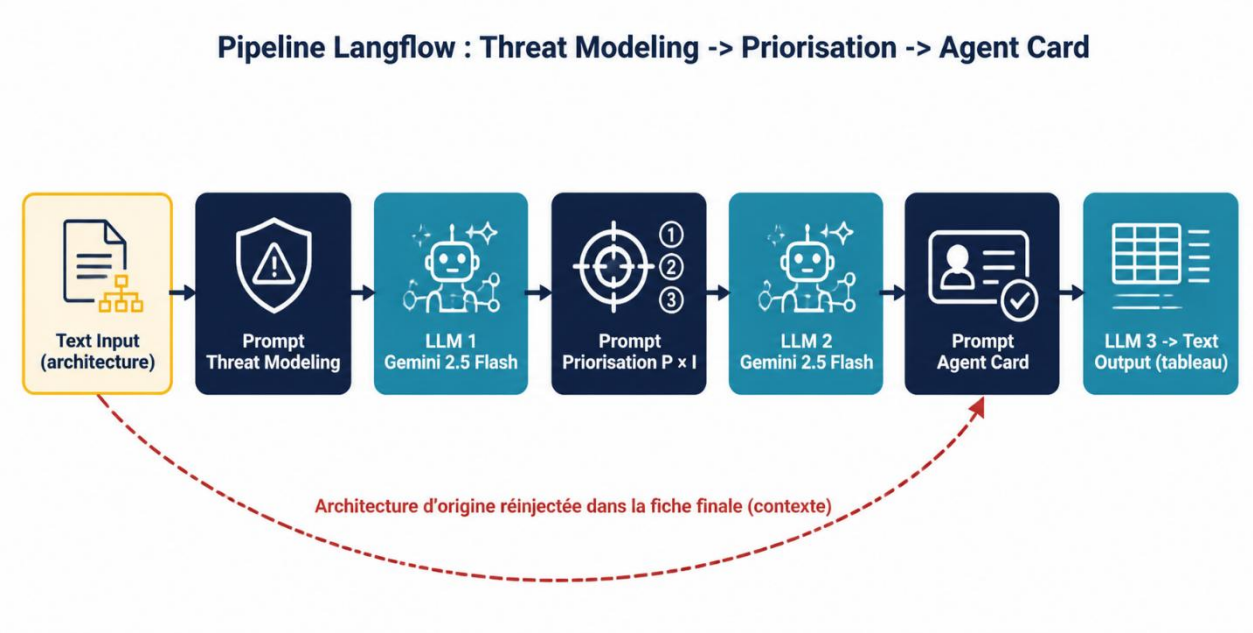
2. Architecture analysée

SupportBot utilise un LLM relié à ChromaDB (RAG : historique des tickets et documentation interne), à un outil API SQL (factures clients) et à un outil d'envoi d'emails de remboursement. Les utilisateurs y accèdent via un chat public.



3. Pipeline Langflow final

Le flux enchaîne trois Prompt Templates et trois modèles Gemini 2.5 Flash (température 0,1). L'architecture d'origine est réinjectée dans la fiche finale pour le contexte.



Corrections apportées au JSON

- Prompt 1 : exactement 5 menaces (au lieu de « au moins 5 » contredisant « uniquement 5 »), séparation Mémoire RAG / Actions Tools, références OWASP et ATLAS imposées.
- Prompt 2 : échelle P et I de 1 à 5, seuils explicites (Critique ≥ 20, Élevé 12–19, Moyen 6–11, Faible ≤ 5), format de sortie strict.
- Prompt 3 : ligne « Référentiels » ajoutée, mitigations alignées sur les trois couches du Goal Guarding, au moins 4 mesures.
- System Messages dédiés pour chacun des trois modèles (Red Teamer, analyste GRC, architecte sécurité).

4. Menaces identifiées

#	Menace	Cible	Référence	Mécanisme
T1	Injection de prompt indirecte via documents RAG	Mémoire RAG	OWASP LLM01 + LLM08 / ATLAS AML.T0051 (LLM Prompt Injection)	Un attaquant dépose un ticket ou un message contenant des instructions cachées ; indexé dans ChromaDB, il est récupéré par similarité et injecté dans le contexte, où le LLM l'exécute comme une instruction (changement d'intention).
T2	Empoisonnement de la base vectorielle (RAG poisoning)	Mémoire RAG	OWASP LLM04 + LLM08 / ATLAS AML.T0020 (Poison Training Data)	Injection massive de tickets falsifiés (politique de remboursement erronée, faux numéros de support) qui deviennent des 'faits' de référence : l'agent diffuse des informations fausses et prend des décisions biaisées durablement.

#	Menace	Cible	Référence	Mécanisme
T3	Action non autorisée : remboursement frauduleux (Excessive Agency)	Actions Tools	OWASP LLM06 + LLM01 / ATLAS AML.T0051 -> abus d'outil	Par injection (directe ou indirecte), l'attaquant force l'appel de l'outil d'emails de remboursement avec des arguments forgés (montant, destinataire) : perte financière sans validation humaine ni schéma strict.
T4	Escalade de privilèges et exfiltration de PII via l'outil SQL	Actions Tools	OWASP LLM02 + LLM06 + LLM05 / ATLAS AML.T0025 (Exfiltration)	L'agent, avec les droits élevés de l'API SQL, est manipulé pour générer des requêtes hors périmètre (factures d'autres clients, IDOR/BOLA, injection SQL) puis les restitue ou les envoie par email à l'attaquant.
T5	Déni de service par boucles de raisonnement et appels massifs	Actions Tools	OWASP LLM10 (Unbounded Consumption) / ATLAS AML.T0029 (Denial of ML Service)	Requêtes conçues pour provoquer des boucles Chain-of-Thought infinies ou des appels répétés à l'API SQL / au LLM, épuisant quotas, coûts et disponibilité du chat public.

5. Priorisation (Risque = P × I)

#	Menace	P	I	Score	Niveau	Justification
1	Action non autorisée : remboursement frauduleux (Excessive Agency)	4	5	20	**Critique**	Probabilité forte (outil à effet direct, pas de Human-in-the-loop), impact maximal : perte financière et fraude.
2	Injection de prompt indirecte via documents RAG	4	4	16	**Élevé**	Probabilité forte (chat public, ingestion ouverte), impact fort sur l'intégrité des réponses et des outils.
3	Escalade de privilèges et exfiltration de PII via l'outil SQL	3	5	15	**Élevé**	Probabilité moyenne (dépend du RBAC), impact très élevé : fuite de données personnelles et conformité (RGPD / loi 09-08).
4	Empoisonnement de la base vectorielle (RAG poisoning)	3	4	12	**Élevé**	Probabilité moyenne (nécessite une ingestion sans contrôle), impact fort et persistant sur toutes les réponses.
5	Déni de service par boucles de raisonnement et appels massifs	4	2	8	**Moyen**	Probabilité forte (chat anonyme), impact modéré : indisponibilité et surcoût, sans compromission de données.

6. Agent Card – Security

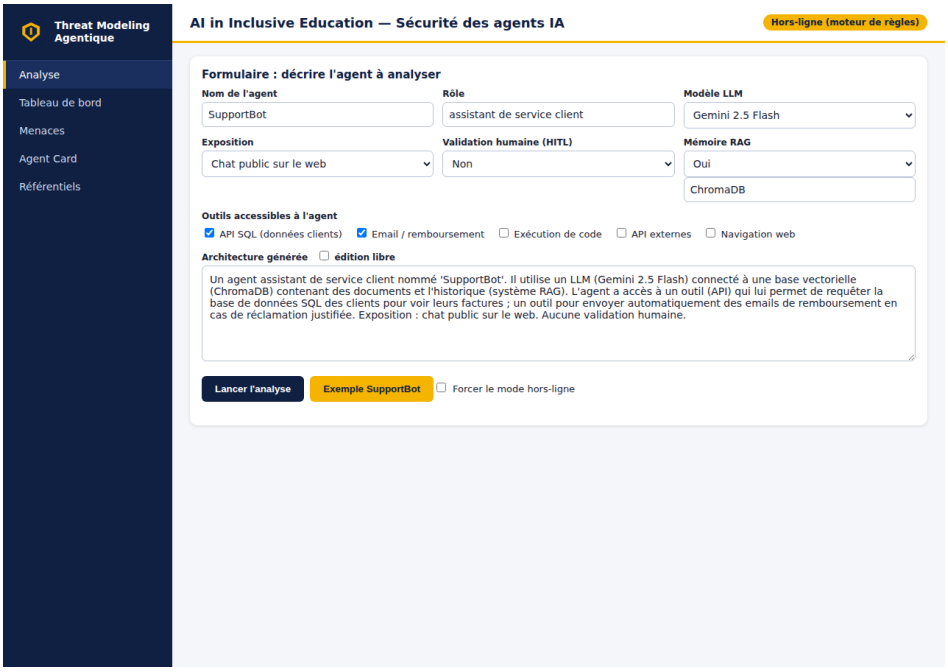
Élément	Spécification de sécurité
Nom de l'agent ciblé	SupportBot (assistant service client RAG + outils SQL/Email)
Scénario d'attaque principal	Action non autorisée : remboursement frauduleux (Excessive Agency) : Par injection (directe ou indirecte), l'attaquant force l'appel de l'outil d'emails de remboursement avec des arguments forgés (montant, destinataire) : perte financière sans validation humaine ni schéma strict.
Vecteur d'attaque	Chat web public → contexte de l'agent (ou ticket empoisonné récupéré par ChromaDB) → outil email de remboursement → effet financier
Impact RAG / Système	Critique : compromission de l'intention de l'agent, effets réels (emails/remboursements), risque d'accès aux données SQL clients
Référentiels	OWASP LLM06 + LLM01 ; ATLAS AML.T0051 ; complémentaires LLM02, LLM04, LLM08, LLM10
Mitigation	Pydantic/JSON Schema sur les outils ; Human-in-the-loop + agent Judge ; System Message immuable ; RBAC et SQL paramétré en lecture seule ; filtrage RAG ; quotas et limites d'itérations

7. Goal Guarding : trois couches de contrôle

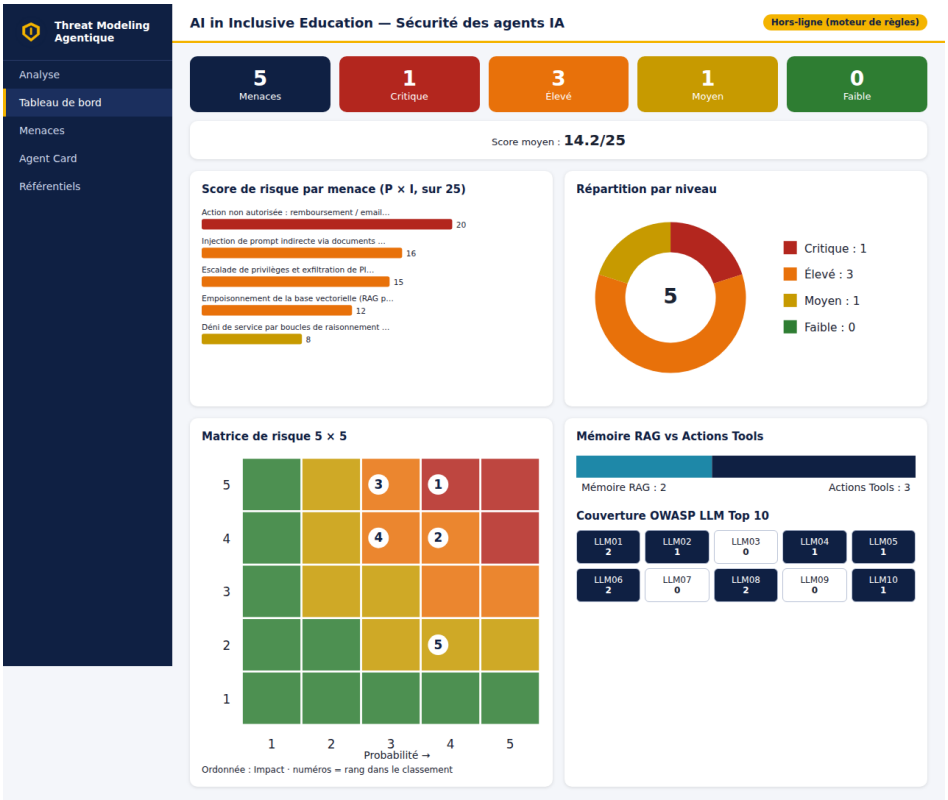
- Structurelle : validation Pydantic / JSON Schema des arguments d'outils avant exécution (montant plafonné, destinataire imposé).
- Métacognitive : agent Judge / Guard comparant l'action prévue au Goal initial et interceptant les dérives.
- Comportementale : System Message immuable réinjecté à chaque tour pour résister aux attaques de réinitialisation.

8. Dashboard (localhost:8000)

Formulaire structuré (nom, rôle, LLM, exposition, validation humaine, mémoire RAG, outils) : l'architecture est composée automatiquement et le moteur adapte les menaces et les scores aux choix effectués.



Menu latéral (Analyse, Tableau de bord, Menaces, Agent Card, Référentiels), KPI, barres de score P × I, donut par niveau, matrice de risque 5 × 5, partage mémoire RAG / actions et couverture OWASP. Les graphiques sont en SVG pur : aucun CDN, compatible avec le réseau filtré de l'ESI.



9. Exécution et livrables

- Importer « Correction AI in inclusive education.json » dans Langflow, renseigner la clé Google (variable Key2), puis lancer le Playground.
- Docker : docker compose up --build (README du dépôt).
- python main.py puis http://localhost:8000 : formulaire, logo et résultats ; bascule automatique en mode hors-ligne si Gemini est inaccessible (réseau ESI filtré).
- j26_Threat_Modeling.ipynb : exécution du pipeline, matrice de risque et graphique.

10. Conclusion

La menace la plus critique de SupportBot est l'abus de l'outil de remboursement (Excessive Agency, score 20/25), déclenchable par injection. Le Human-in-the-loop, la validation stricte des arguments et le moindre privilège ramènent ce risque à un niveau acceptable ; le RAG doit en parallèle être protégé par un contrôle de provenance des documents.